A Payment Firewall for AI Agents: Bounded Spending Under Agent Compromise, and What Refunds Leak

Adarsh Kumar
Department of Electrical Engineering
Indian Institute of Technology Patna
adarsh_2501ec16@iitp.ac.in

November 2026

Abstract

AI agents are beginning to pay for the services they use: under x402, an agent answers an HTTP 402 response with a signed stablecoin authorization. It decides what to buy by reading text written by the party it pays, and in the common design the same process holds the key. We ask what spending authority survives when that process is fully compromised. In our design the agent can only request a payment. A contract holds the user's budget and per-call cap, and a signer accepts only a goal and a sequence number and signs a payment that only x402's auth-capture escrow can collect, with the contract as operator, so every payment passes the contract's checks on the canonical chain. The payer is derived for the user's wallet, and a goal opens only with the signer's statement saying so. For a goal with an honest setup and signer we prove, over an explicit transition model, that lifetime vendor payments total at most min(budget, cap $\times$ calls), whatever the agent does and whatever the signer's RPC reports; 262,144 fuzzed transitions against the deployed escrow's code and a live campaign of 29 attack strategies, with the signer in an Intel TDX enclave, found no violation. Encrypting the limits (Inco Lightning) buys less than it seems. Refunds of unpaid approvals made the policy free to probe; a public attempt budget bounds the decision channel to m bits, yet on realistic caps a vendor with five probes prices within 4% of the cap. In matched runs on Base Sepolia a paid call took a median of 2.0 s with plain x402, 6.7 s with plaintext on-chain limits and 21.6 s with encrypted ones. We also specify a key-release protocol for digital goods whose dispute predicate the contract decides itself.

1 Introduction

Language-model agents increasingly act on the web on a user's behalf: they search, call APIs and assemble results. Paying for those calls has required accounts, cards and invoices that an autonomous agent cannot hold. The x402 protocol [1] removes that barrier. A server answers a request with HTTP status 402 and a machine-readable price, the client returns a signed stablecoin authorization [2], and settlement on a blockchain takes seconds.

An agent that buys this way must do two things. It must read what the seller sends (price, payee and a free-text description) to decide whether a purchase serves its goal, and it must then produce a payment. In the common design both happen in one process, and that process holds the signing key. This is where *indirect prompt injection* [14] does the most damage: text a seller places in its own description can steer the agent, and a steered agent with a payment key moves money that cannot be recovered. A 2026 code review, summarised by the Cloud Security Alliance [21], reported that default x402 clients applied no spending limit until fixes in August 2026, and the per-payment cap those fixes added can be switched off by a flag.

Separating the model's reasoning from spending authority is not new. CaMeL [16] checks capability policies outside the model that reads untrusted data, and PACE [23] has a verifier sign each transaction a smart account will execute. We take that separation as given and ask a narrower question: when the agent's process is fully compromised, what spending authority does it keep over the life of a goal, and what does it learn about the user's limits? Answering it for x402 turned up three problems that a design for this setting has to solve, and they organise this paper.

The first is that a signature outlives the approval behind it. An EIP-3009 transfer signed for an approved request can be collected whatever later happens to the approval, so the signer must be right about the chain: a lying RPC endpoint, or an approval on a block that is later dropped, becomes money. We remove that dependence by signing only payments that x402's auth-capture escrow can collect, with the policy contract as the escrow's operator, so the contract's own checks run on the canonical chain when money moves (Section 4.5). The second is setup. The user funds an address that reaches the console through the agent's process, so a compromised agent can name an address it holds. The payer is now derived for the user's wallet inside the signer, and a goal opens only with the signer's statement saying so (Section 4.2). The third is leakage. Refunding an approval that was never paid is necessary for accounting and makes the policy free to question: a request that consumes nothing still has its decision published. A private policy then needs a separate budget of questions, and even with one, the private limit protects less than its encryption suggests (Section 8.6).

Contributions.

1. *Escrow-gated authorization with authenticated setup, and a lifetime spending bound.* Under an adversary with arbitrary code execution in the agent, on a goal whose setup and signer are honest, vendor payments over the goal's life total at most $\min(\text{budget}, \text{cap} \times \text{calls})$, to allowlisted payees only, whatever the signer's RPC reports. We state the bound over an explicit transition model, prove the invariants it rests on for every transition, and test them by stateful fuzzing against the deployed escrow's code, by mutation, and by a live adversary campaign (Sections 4–5 and 8).
2. *Refund-induced leakage.* Reclaim, which restores spending capacity to unpaid approvals, let an adversary binary-search the encrypted cap of our own deployed contract without permanently consuming budget or calls (gas, fees and time still cost). A public attempt budget bounds the decision channel to m bits of average min-entropy leakage, under assumptions we state in the theorem. On realistic cap distributions the bound leaves little: a vendor with five probes prices within about 4% of the cap (Sections 4.8, 5.2 and 8.6).
3. *A matched comparison.* Plain x402, the same escrow path with plaintext on-chain limits, and the confidential design, measured interleaved on the same network, relay and vendor; an enclave-held policy with on-chain rollback protection, built and measured on a fork; and an injection study that gives every arm the same agent interface (Section 8).

We also specify a key-release protocol for digital goods that a vendor is paid for only by publishing the decryption key, with a dispute predicate the contract decides itself; the predicate is built and measured, and the rest of the protocol is not (Section 6). The live campaign, a benchmark and a storage-wipe test ran with the signer in an Intel TDX enclave on Oasis ROFL; the matched baselines used a signer on a local machine (Section 8).

Terms. We keep four events apart throughout. *Authorization* is the vault's approval of a request and the signer's signature over it. *Funding* moves the payer's tokens into the escrow. *Capture* pays the vendor from the escrow. *Delivery* is the vendor handing over what was bought, which nothing in the implemented system ties to capture.

2 Background

x402 and EIP-3009. In x402's `exact` scheme a server's 402 body lists the payments it accepts: network, asset, payee, maximum amount, resource, a free-text description and `maxTimeoutSeconds`, the "maximum time allowed for payment completion". It is a deadline for one exchange, not a reservation. An optional Offer and Receipt extension [7] lets the server sign its terms, including an optional *validUntil*. The client signs an EIP-3009 [2] authorization, an EIP-712 [3] typed message (*from*, *to*, *value*, *validAfter*, *validBefore*, *nonce*). A token executes each (*from*, *nonce*) at most once and refuses it at or after *validBefore*. In `transferWithAuthorization` anyone may submit the message; in `receiveWithAuthorization` only its *to* address may. The `exact` scheme also defines an ERC-7710 [6] delegation method under which a smart account pays; we return to it in Section 9.

Auth-capture. x402's `auth-capture` scheme [8] runs on the commerce-payments `AuthCaptureEscrow` [9]. A payment is a `PaymentInfo` struct: operator, payer, receiver, token, maximum amount, three deadlines, fee bounds, fee receiver and a salt. The payer signs a `receiveWithAuthorization` to a token collector. The escrow accepts `authorize` (fund and hold), `charge` (fund and pay at once), `capture` and `void` only from the struct's operator; the payer alone may `reclaim` a hold once its capture deadline has passed. Section 4.6 gives the exact encoding and what each contract checks.

Inco Lightning. Inco Lightning [11] lets contracts on Base hold encrypted values, represented on chain by 32-byte *handles*. Users encrypt inputs on the client, and a contract converts a ciphertext into a handle bound to the submitting address. Operations such as comparison, conjunction, selection and subtraction return new handles at once and emit events; Inco's covalidators, running in trusted hardware off chain, evaluate them afterwards. A contract cannot branch on an encrypted value. It may mark a handle for public decryption, after which a threshold of covalidators signs the plaintext and the contract verifies that signature on chain. Confidentiality and correct evaluation both rest on Inco's covalidators and their hardware; Lightning is not homomorphic encryption.

Oasis ROFL and Intel TDX. Intel TDX runs a virtual machine whose memory is protected from the host and can be remotely attested. Oasis ROFL [13] runs containers in such machines under a policy registered on the Sapphire chain, which lists the enclave measurements the application accepts, and derives keys deterministically from the application's identity and a key identifier, releasing them only to instances that policy admits.

3 Threat Model and Assumptions

We consider three adversaries. **A1**, a persuasive vendor, controls everything a resource server returns, including prices, payees and descriptions, and aims to make the agent pay more, more often, or to someone else. **A2** has arbitrary code execution in the agent's process, the *orchestrator*: it holds the relay key, relays everything between the signer and the user's console, and may submit any request to the policy contract and any query to the signer, in any order. A2 subsumes A1, and our claims about the agent are made against A2. **A3**, a dishonest vendor, collects a payment after its hold has

ended, or collects in time and delivers nothing or something worthless. The implemented system addresses late funding; non-delivery is the subject of Section 6.

What the adversaries cannot do. Break Keccak-256 or ECDSA over secp256k1; obtain the user's wallet key; rewrite the canonical chain. The signer's RPC endpoint may lie, and blocks may be dropped from the chain it reads; for payment authorization after a stable, authenticated setup this costs liveness and cannot widen the loss bound (Section 4.5). The leakage theorem makes a stronger assumption about dropped blocks, stated in it (Section 5.2).

Trusted components. The loss bound assumes an uncompromised signer: the payer is an ordinary key, so a compromised signer can sign a plain transfer and take the funded balance. It also trusts the ROFL application's administrator, who can change which enclave measurements receive the application's keys. The user's console and the user's own RPC endpoint are trusted; the console is built with the vault address and the signer's enrollment address fixed.

Inco. We separate what we assume of Inco from what we test, since a verified signature establishes only that a threshold of covalidators endorsed a plaintext. We assume:

(I1) *Correct evaluation:* each handle an operation returns evaluates to that operation applied to the plaintexts of its inputs.

(II2) *Ordered evaluation and binding:* the operation graph is evaluated in the order of the canonical chain's transactions and events, so that the budget handle a request reads is the one the previous transaction wrote, and the decision handle the vault stores for (g, s) is the one that request computed.

(III3) *Unforgeable attestation:* a threshold signature verifies for (h, v) only if handle h evaluates to v.

(IV4) *Access control:* only the vault can use the budget and cap handles as operands.

(V5) *Confidentiality:* no plaintext of a budget or cap handle reaches anyone; only the decisions the vault reveals are decrypted.

The loss bound needs I1 to I4; the leakage theorem needs I5 as well. What this paper tests is the contract logic *given* these properties, using Inco's test double, and the live behaviour of the deployed service in our runs; neither establishes the properties themselves. If I1 or I3 fails, the public call count, the allowlist and the funded balance still bound the loss.

4 Design

4.1 Overview

Figure 1 shows the components. The *orchestrator* runs the language model and an x402 client, and is untrusted. The `EscrowPolicyVault` contract holds each user's policy, records every request and decision, and is the operator of every escrowed payment. The *signer* holds the enrollment key and the payer keys. The user acts once per *goal*: the console obtains an enrollment statement for a fresh payer, checks it, sends `openEnrolledGoal` from the user's wallet with an encrypted budget, an encrypted per-call cap, a public call count, a public attempt budget, an expiry and a payee allowlist, and, once that transaction has a few confirmations, funds the payer with an amount chosen independently of the budget (Section 5.3). The user's wallet grants no allowance and never signs a payment.

A paid call proceeds as follows. The orchestrator receives a 402, parses it strictly, and lets the model decide only whether to proceed; amount, payee and asset come from the parser. The relay key submits `requestEscrowSpend(goalId, amount, payTo, resource, payBy, captureDeadline, keyHash)`. After Inco evaluates the request, anyone may submit the attested decision to `finalizeDecision`. The orchestrator asks the signer to authorize $(goalId, seq)$ and attaches the signature to its retry. The vendor's facilitator calls the vault's `authorize`, which funds the escrow, and the vendor then calls the vault's `claim` to be paid. A paid call is four transactions, one of them the vendor's. Figure 4, after the references, gives every message.

4.2 Authenticated enrollment

The user funds the payer, and the payer's address reaches the console from the signer through the orchestrator. Under A2 that path can substitute an address the attacker holds, and the user would fund it directly: no request, policy or signature would be involved. Earlier versions of this system stated this as a limit. Enrollment closes it.

Derivation. The console draws a fresh 32-byte *enrollment identifier* e and asks for a payer for its own wallet o. The signer derives the payer's key from the identifier *payer*/*chainId*/*vault*/o/e and returns the address with a statement σ_E, an EIP-712 signature by its *enrollment key* over $(payer, o, e)$, whose domain names the chain and the vault. Because the payer is a function of o, no statement for a payer can ever name a different owner: not one requested by a hostile orchestrator, and not one issued after a restart that lost the signer's memory. The signer keeps no state about payers; the goal record names the owner and the vault records e, so the key for any goal is re-derived from the chain. The enrollment key's identifier names only the chain, so its address can be read before the vault that pins it is deployed.

Checks. The vault fixes the enrollment address at deployment and accepts `openEnrolledGoal`$(params, e, \sigma_E)$ only if σ_E recovers to it for $(params.payer, msg.sender, e)$; the unchecked `openGoal` reverts. The console, before sending anything, checks the statement against the enrollment address built into it, compares that address with the vault's `enrollmentSigner()` through its own RPC endpoint, and checks the owner, identifier, chain

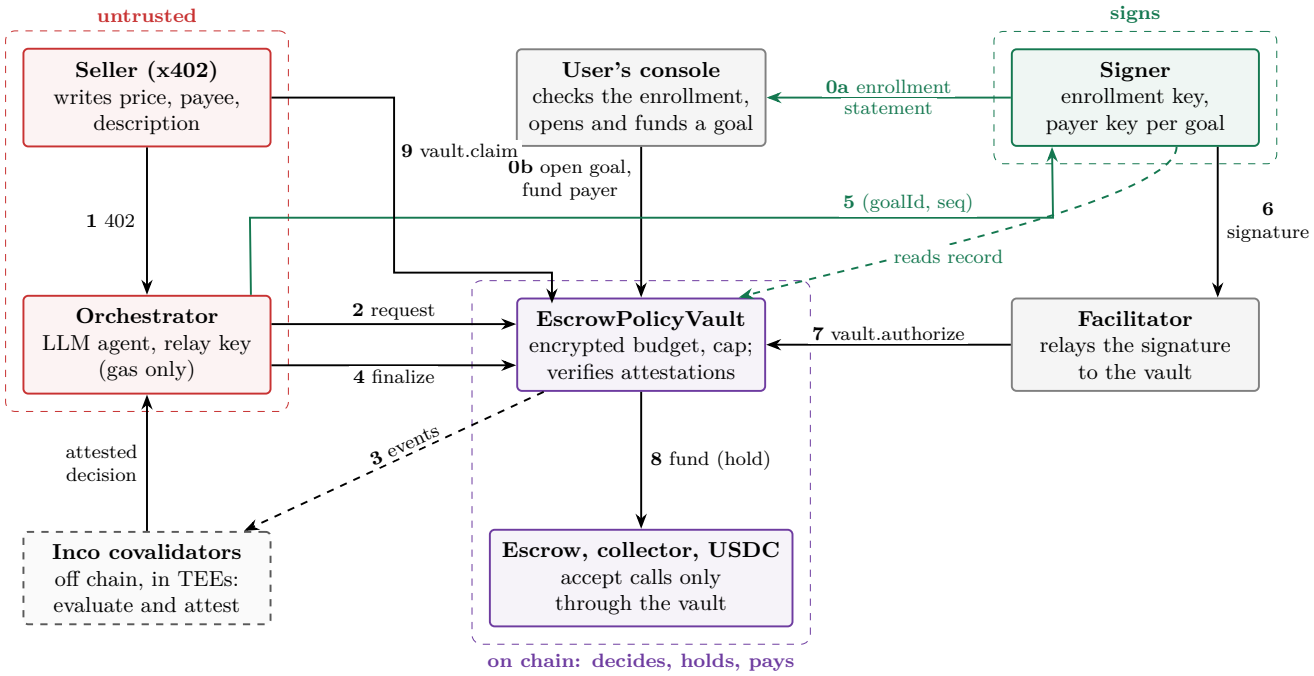


Figure 1: Architecture and one paid call. Red components read attacker-controlled text. Inco's covalidators evaluate off chain and attest; the vault verifies the attestation on chain. The signer's only input from the orchestrator is (*goalId*, *seq*), and its signature moves money only through the vault's `authorize` (7, 8); the vendor is paid by `claim` through the vault (9).

and vault. Before funding it waits three blocks after the setup transaction and re-reads that the vault binds this payer to this goal, that the goal is this wallet's, and that it was opened under e.

The connection to the measurement. In a ROFL deployment the enrollment key is derived by Oasis's key manager from the application's identity and the identifier `enrollment/<chainId>`, and released only to instances the application's on-chain policy admits. That policy lists the accepted enclave measurements. A valid statement therefore comes from an admitted instance, unless the key manager or the administrator who sets the policy is compromised. On a laptop the key comes from a seed file, and a statement means only that whoever holds the file signed it. We deployed the vault both ways and say for each run which one it used (Section 8.3).

Finality of setup. The adversary model allows dropped blocks, so a confirmed setup can disappear after the user has funded the payer. The payer is then unbound, but every statement for it names this owner, and the vault reads the owner from the sender, so no other wallet can bind it; the owner can open the goal again with the same statement, and the funds wait in a payer only this owner's goal can use. Front-running fails for the same reason: a statement seen in the mempool opens nothing for another sender. The confirmations narrow the window; they do not carry the argument.

4.3 Policy state and the debit

For each goal the vault stores the remaining budget B and the cap C as encrypted handles, and the call count n, attempt budget m, allowlist A, asset, expiry and relay in plaintext. The requested amount is public by design: were it encrypted, the orchestrator could submit one ciphertext to the check and other terms to the signer. Structural conditions (caller is the relay, goal open and unexpired, payee in A, non-zero amount, hold not passed, an attempt left, no request pending) revert. Policy conditions (budget, cap and call count) resolve into a recorded approval or rejection, so a refused request stays visible on chain.

The debit is written as a selection, since a contract cannot branch on an encrypted value:

```
ok     = B[g].ge(a).and(C[g].ge(a));                    //
     encrypted: a <= B and a <= C
debit  = ok.select(a.asEuint256(), uint256(0).
     asEuint256());
B[g]   = B[g].sub(debit);  B[g].allowThis();            //
     new handle, retained by the vault
ok.reveal();                                            //
     only the decision becomes public
```

All of this runs in the transaction that records the request, its sequence number s, a hash of its terms and a frozen validity window. If the public call count is zero the vault records a rejection without touching the budget. Both limits are combined in one condition, so a rejection does not say which limit refused. The call count moves at finalization, and only on approval, which is why requests on a goal are strictly sequential.

This *write-ahead* debit is a construction choice, not a security principle the bound needs. With one request pending per goal, a design that debited at finalization, before any approval could be signed, would satisfy the same invariants; ours is what Inco makes expressible, since the debit must be computed where the comparison is. What the choice changes is the accounting: a pending request has already debited, so the invariants of Section 5.1 carry a term Q for it. Selecting the operand,

not the result, keeps the subtraction defined on every path. Every debit produces a new budget handle to which only the vault is granted access.

4.4 Finalization and the signer

`finalizeDecision`(g, s, v, σ) verifies that the covalidator signatures σ attest plaintext v for *the decision handle stored for* (g, s), never one the caller supplies. Anyone may call it.

The signer accepts (g, s) and nothing else. It reads the goal and the request, refuses unless the request is finalized, approved, not reclaimed, on an open goal, in the expected asset and inside its frozen window, re-derives the payer's key from the goal's owner and enrollment identifier, and refuses if that key is not the goal's payer. It then signs one kind of message: a `receiveWithAuthorization` from the payer to the pinned collector, described in Section 4.6. The operator, collector, escrow and token come from configuration fixed at boot, never from the chain, and the signer has no code path to a plain transfer. The record is frozen, so repeating the query gives a byte-identical signature. These refusals tell a caller why nothing was signed; since the vault checks again when money moves, they are not what makes a signature safe.

After the owner closes a goal, the signer also signs a *sweep* of the payer's remaining balance, payable to the goal's owner, through the vault's `charge`, which checks on chain that the goal is closed, the receiver is its owner and no fee is taken.

4.5 Collection through the escrow

An EIP-3009 transfer signed for an approved request stays valid whatever later happens to the approval. In version 1 of this work that put the signer's RPC inside the trusted base: an invented approval reported by a malicious endpoint would be signed, and a signature released for an approval on a dropped branch survived the branch. With $B_0 = C = 0.20$ and $n_0 = 1$, an approval of 0.10 on a discarded branch and a canonical approval of 0.20 at the same sequence number carried different nonces, so the token accepted both and paid 0.30. Waiting for finality was not practical: on 6 November 2026 Base Sepolia's `safe` block was about 23 minutes behind the head and its `finalized` block 3.8 hours, against a 60-second hold.

In the escrow design the vault is the operator of every payment. The vault's `authorize` derives the payment from its own record and requires the caller's struct to equal it in every field, the record to be finalized, approved and not reclaimed, the goal to be open, the amount to be the whole recorded amount, and the collector to be the pinned one; only then does it call the escrow. In the example above, the 0.10 signature names a record that does not exist on the canonical chain, so it is refused and the payment is 0.20. The inherited `requestSpend` reverts on this vault, so a goal has no other way to spend.

An approved request has three endings: paid, returned, or never funded. Table 1 gives the rule for crediting it back. The vendor captures with `claim`(g, s, k), which only the recorded payee may call and which requires a preimage of the request's key hash if one was set. Closing a goal stops funding, because `authorize` requires an open goal; funds already held can be claimed until their deadline and come back through a reclaim after it.

4.6 The end-to-end binding

Several contracts stand between a signature and a payment, and the loss bound depends on all of them. We state what binds what, for the deployments our runs used.

The signed message. The payer signs, under USDC's EIP-712 domain (name, version, chain id, token address), `ReceiveWithAuthorization`$(\mathit{from} = \mathit{payer}, \mathit{to} = \mathit{collector}, \mathit{value} = \mathit{maxAmount}, \mathit{validAfter} = 0, \mathit{validBefore} = \mathit{preApprovalExpiry}, \mathit{nonce})$, where

$$h_0 = \mathrm{keccak}(\mathrm{enc}(\mathit{TYPEHASH}, \mathit{info}[\mathit{payer} := 0])),$$
$$\mathit{nonce} = \mathrm{keccak}(\mathrm{enc}(\mathit{chainId}, \mathit{escrow}, h_0))$$

is the escrow's own payment hash with the payer zeroed, and enc is ABI encoding. The nonce therefore covers every field of `PaymentInfo` except the payer (operator, receiver, token, maximum amount, the three deadlines, fee bounds, fee receiver and salt), plus the chain and the escrow; the payer is covered by *from*. The salt is $(g \ll 64) \mid s$, which makes the nonce unique per request and lets the vault find the record.

Who may submit it. USDC accepts `receiveWithAuthorization` only from *to*, the collector. The collector acts only when called by the escrow, and checks that the nonce equals the escrow's payer-agnostic hash of the payment it is given. The escrow accepts `authorize` and `charge` only from the payment's operator, the vault. So a signature can move tokens only inside the vault's `authorize` or `charge`, and both re-derive the payment from the vault's record.

Every other route. The escrow's operator-only functions are `authorize`, `charge`, `capture`, `void` and `refund`. The vault calls `authorize` after its checks, `charge` only for a sweep to the owner of a closed goal, `capture` only in `claim` for the recorded payee and the whole amount with no fee, and `void` only in a reclaim after the capture deadline. It never calls `refund`. The payer's own `reclaim` returns a hold to the payer after the capture deadline, which Table 1 counts. Because the vault never refunds and captures only the whole amount, the escrow's `refundableAmount` is non-zero exactly when a payment was captured, which is what lets `reclaimExpired` tell "paid" from "returned". In another integration that called `refund`, that inference would fail.

Escrow state	Time	`reclaimExpired`
Not funded	before *validBefore*	refused: the signature is still live
Not funded	from *validBefore*	credit: token and escrow both refuse the signature from then on
Held	before capture deadline	refused: the vendor can still claim
Held	from capture deadline	void, funds to payer, credit
Funded, nothing held, nothing captured	any	credit: the payer took the funds back directly
Captured	any	refused: paid

Table 1: What decides a reclaim. The state is read from the escrow.

Versions and code identities. The escrow is commerce-payments v1.1.0 [9] (commit `6b0a5ef`), at `0xf968...B19c` on Base and Base Sepolia, with the ERC-3009 collector at `0x8612...ab88`. Neither is a proxy. At Base Sepolia block 56,480,000 the keccak hashes of their deployed code begin `0x33558f6c` and `0xe27322c8`, and the escrow's token-store template's `0x8ff35d5d`. USDC is Circle's upgradeable proxy (code hash `0xedc5281a`), with implementation `0xd74c...C5B5` (`0x1254951e`) at that block; an upgrade by its administrator is outside our model. The repository's test fixture records the code and every storage slot these contracts read, at that block.

4.7 The recorded funding deadline

x402 offers no reservation. We take the vendor's deadline T to be the end of the payment window it declares: the orchestrator records when the 402 arrived, adds `maxTimeoutSeconds` and passes the result as *payBy*. The vault sets

$$\mathit{validBefore} = \min(\mathit{payBy},\ t_{\text{request}} + 1\,\text{h},\ \mathit{expiry}),$$

after which the token and the escrow both refuse to fund the payment, and records a capture deadline at or after *validBefore*, at most one hour later and not past the goal's expiry, after which the escrow refuses capture. What the implementation guarantees is therefore a *recorded funding deadline*: funding before *validBefore*, capture before the capture deadline. It does not guarantee that *payBy* equals the vendor's own deadline (under A2 the orchestrator chooses it, within the hour), that capture happens before T, that the vendor still holds what it offered, or that funding causes delivery. Even an honest orchestrator computes *payBy* from a relative timeout, so transit delay and a difference between the vendor's clock and the chain's need a margin.

Before committing, the orchestrator checks that enough of the hold remains for the request to be funded. The threshold is a heuristic, set from measurement: in our runs the time from the request to funding had a maximum of 23.8 s (Section 8), and the check uses 30 s. It is not a guarantee of success.

Approval does not move money. A crash, an abandoned request or a vendor that never claims can leave the budget reduced by money that was not paid. `reclaimExpired`(g, s) returns the amount to the budget and the call to the count in the cases of Table 1. Anyone may call it, since every condition is read from the chain. It needs finalization first, so a request whose decision Inco never reveals cannot be reclaimed; the owner's close and sweep is then a separate recovery. Reclaim restores accounting and not necessarily the ability to spend: the goal must still be open, unexpired and have an attempt left.

4.8 The attempt budget

Every requested amount and every decision is public, so each request answers one question about the encrypted limits: is $a \le \min(B, C)$? Whoever chooses the amounts chooses the questions. Rejections never consumed anything, and once reclaim existed an approval left to expire consumed nothing either: name a *payBy* one second away, never fund, reclaim. Our regression test recovers a secret cap of 137,391 units exactly in 23 requests by binary search, reclaiming every approval, so budget and call count end where they began. This is the general lesson of the paper's second contribution: a mechanism that restores spending capacity also restores the ability to ask, and in a private policy asking is what leaks.

The goal therefore carries a public attempt budget $m \ge n_0$, set by the owner. Every request spends one attempt, approved or rejected, and nothing returns it. The attempt is kept apart from the call: a call is a payment the owner agreed to fund and comes back if unused, an attempt is a question already answered. The attempt budget is also a resource a vendor can exhaust: quotes above the limits make an honest agent spend attempts on rejections. Section 8.6 measures the trade between leakage and honest completion.

4.9 Execution traces

Each run produces a hash-chained trace whose payment steps carry the decision handle, the covalidator signatures and the commit transaction; rejected attempts stay in it. Only a Merkle root is stored on chain, once per (vault, goal). The anchor is permissionless and its first write is final, so anyone can occupy a goal's slot with an arbitrary root; verification rejects that root, at a cost in audit availability only.

5 Security Analysis

Property 2 and Theorem 3 hold under A2, for a goal whose enrollment was authentic and whose signer is

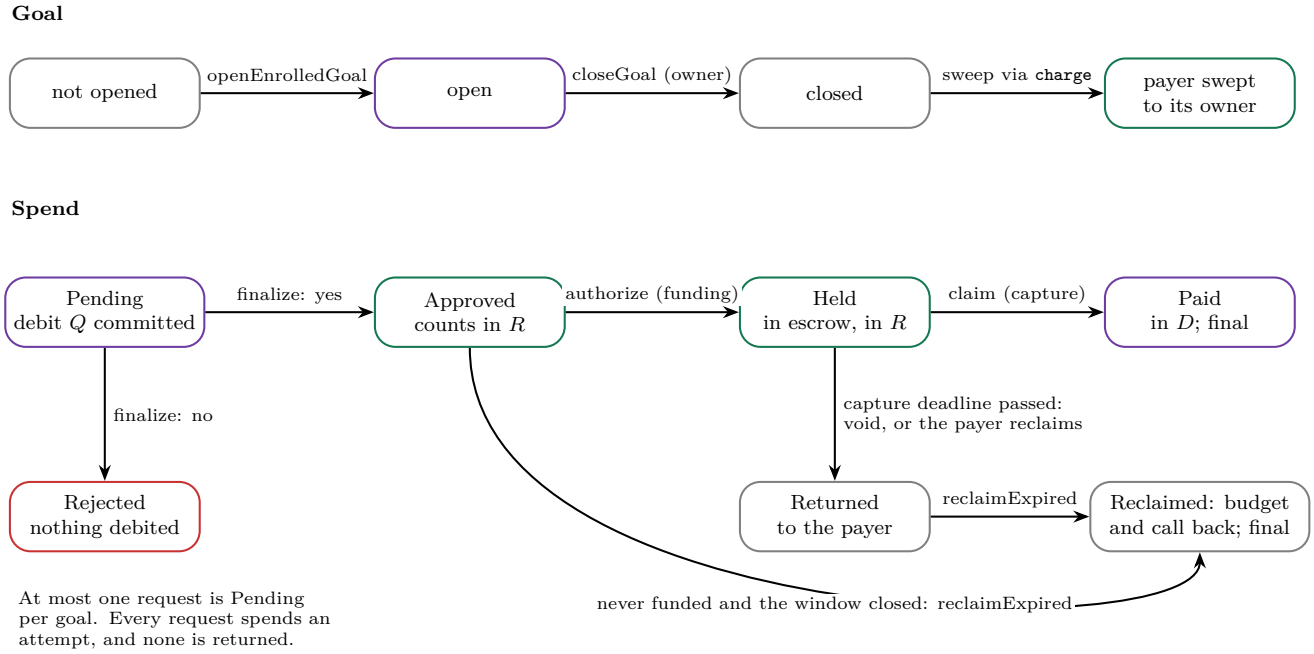


Figure 2: Lifecycle of a goal and of one request, with the accounting term each state counts in (Section 5.1).

uncompromised, with Inco satisfying I1 to I4. Property 4 is about the recorded deadline. Theorem 7 is about the decision channel and states its own assumptions. The arguments are by hand over the transition model below; we have not mechanised them. Section 8 reports how each is tested and with what.

5.1 Transition model

Fix a goal opened with budget B_0, cap C, call count n_0, attempt budget m_0, allowlist A and funding F. Each request s is in one state: Pending, Rejected, Approved (finalized, not funded), Held (funded, not captured), Paid, or Reclaimed. A held payment the payer took back, or one past its deadline not yet voided, is still Held in the vault's accounting until it is reclaimed (Figure 2). Write a_s for its amount and define

- $D = \sum_{s \in \mathsf{Paid}} a_s$, the lifetime vendor payments;
- $R = \sum_{s \in \mathsf{Approved} \cup \mathsf{Held}} a_s$, the reserved, unresolved amounts;
- $Q = a_p \cdot [\, ok_p \,]$, the debit of the pending request p, if there is one;
- $L = |\mathsf{Approved} \cup \mathsf{Held} \cup \mathsf{Paid}|$, the live approvals,

where ok_p is the pending request's encrypted decision, which exists from the request on and is revealed later. Let B be the plaintext of the budget handle, n the call count, m the attempts left and σ the last sequence number. The claims are

(J1) $B + D + R + Q = B_0$;
(J2) $n + L = n_0$;
(J3) $m + \sigma = m_0$;
(J4) no request is both Paid and Reclaimed, and each is reclaimed at most once.

J2 counts Paid approvals and leaves the pending request out, because the call count moves at finalization.

Proposition 1 (Invariants)**.** *Under I1 to I4, J1 to J4 hold in every reachable state of a goal on the canonical chain.*

Proof. Initially $B = B_0$, $n = n_0$, $m = m_0$, $\sigma = 0$ and all sums are zero. Table 2 lists every function that changes a goal's state and shows each preserves J1 to J4; anything else reverts or leaves the goal unchanged. Two points need the assumptions. J1 equates a plaintext with handle arithmetic, which needs I1 and I2: the budget handle each request reads is the one the previous transaction wrote. And the Approved/Rejected split equals *ok* only if the finalized value is the attested one, which is I3 together with the vault verifying against the handle it stored. □

Property 2 (No authority from text)**.** *No signature issued by the signer moves money to anyone other than the goal's owner unless the vault's record on the canonical chain holds (g, s) as finalized, approved and not reclaimed when the payment is funded, and the signed terms equal the terms recorded at request time.*

The signer consumes no terms from its caller, and by Section 4.6 a signature moves tokens only inside the vault's `authorize`, which re-derives and compares the whole payment, or `charge`, which pays only the owner of a closed goal.

Theorem 3 (Lifetime loss bound)**.** *Under A2, for a goal whose enrollment was authentic and whose signer is uncompromised, with Inco satisfying I1 to I4, the lifetime vendor payments satisfy $D \le \min(B_0, C \cdot n_0)$, every payment goes to a member of A, and each is at most C. Separately, vendor payments and sweeps together never exceed the payer's funding F plus any tokens others sent it: held funds that return to the payer are counted once, when they are paid or swept. The bound holds whatever the signer's RPC reports and whatever blocks are dropped after the enrollment is stable. Gas, the relay key's spending and lost availability are outside it.*

Transition	Effect	Why J1 to J4 are preserved
request (a)	$\sigma{+}1$, $m{-}1$; $B \mathrel{-}= a \cdot ok$; new Pending	Q rises by exactly what B falls (J1); $m + \sigma$ fixed (J3). Only with no request pending, so Q was 0. If $n = 0$, $ok = 0$ in plaintext.
finalize, approved	Pending→Approved; $n{-}1$	Q moves into R (J1); $L{+}1$, $n{-}1$ (J2). Needs $n \geq 1$, guaranteed since ok required it at request (I1, I2).
finalize, rejected	Pending→Rejected	$Q = 0$ before and after (J1).
authorize (fund)	Approved→Held	Stays in R and L. Refused unless approved, not reclaimed, goal open, terms and amount exact.
claim (capture)	Held→Paid	a moves from R to D (J1); stays in L (J2). Escrow refuses after the capture deadline.
payer's reclaim	funds back to payer	No accounting change: still Held in the vault until credited.
reclaimExpired	Approved/Held→Reclaimed; $B{+}a$, $n{+}1$	a moves from R to B (J1); $L{-}1$, $n{+}1$ (J2); m unchanged (J3). Only in Table 1's cases, never from Paid; a flag stops a second credit (J4).
close, sweep	goal closed; payer's balance to owner	No accounting change; `authorize` and `requestEscrowSpend` then refuse.

Table 2: Every transition of a goal and why it preserves the invariants. A reclaim of an older approval while a newer request is pending changes R and B only, and leaves Q as it was.

Proof. By J1, $D \leq B_0$, since B, R and Q are non-negative. Every paid request was approved, and approval needs $a \leq C$ by I1 and I3, so each payment is at most C. Paid requests are live approvals, so $|\mathsf{Paid}| \leq L \leq n_0$ by J2, and $D \leq C \cdot n_0$. Payees are checked against A structurally at request, and capture pays the recorded payee. By Property 2 only records on the canonical chain count, which is why neither the RPC nor a dropped block can add to D. For the second bound, every token that leaves the payer goes to the escrow or to the owner; the escrow pays out only by capture or returns to the payer, so the payer's balance plus held funds plus D plus sweeps equals F plus inflows at all times. Authentic enrollment is needed because otherwise the payer the user funds might not be the one the goal names; an uncompromised signer because the payer is a key. □

Property 4 (Recorded funding deadline)**.** *A signature for a request cannot fund the escrow at or after its recorded validBefore, and the vendor cannot capture at or after the recorded capture deadline. Whatever the orchestrator reports, no payment is funded an hour or more after its request, or captured two hours or more after it.*

The window is frozen in the record and is the one signed; the token and the escrow enforce it. This is a property of the recorded deadline only. It protects a buyer against a late-collecting vendor if the orchestrator reports the hold honestly and with a margin for transit and clocks; under A2 it weakens to the hour, without weakening Theorem 3. Authenticated commercial holds need the vendor's signature on an absolute deadline, as in Section 6.

Property 5 (Reclaim cannot double-pay)**.** *For every (g, s), the amount is never both captured and credited back, and is credited at most once.*

This is J4. A credit needs nothing captured. If nothing was funded, it needs $t \geq validBefore$, after which funding is impossible. If funds are held, it needs the capture deadline to have passed, after which capture is impossible, and the funds are voided in the same transaction.

5.2 The decision channel

Definition 6 (Decision-channel leakage)**.** *The secret is $\mathsf{s} = (B_0, C)$ and P is the public setup: everything public before the first request, including the funded amount, expiry and allowlist. The pair (s, P) has any joint distribution, and every goal has attempt budget at most m. Before request i an adaptive adversary chooses which earlier approvals ρ_i to reclaim and an amount a_i, as functions of P, its coins r and everything public so far, and observes $d_i = [\, n_i \geq 1 \,] \wedge [\, a_i \leq B_i \,] \wedge [\, a_i \leq C \,]$. Its view after $k \leq m$ requests is $V = (\rho_1, a_1, d_1, \ldots, \rho_k, a_k, d_k)$. The leakage is $\mathcal{L} = H_\infty(\mathsf{s} \mid P) - H_\infty(\mathsf{s} \mid P, V)$, with $H_\infty(X \mid Y) = -\log_2 \sum_y \max_x \Pr[x, y]$ the average conditional min-entropy [37].*

Theorem 7 (Decision-channel bound)**.** *Assume that the adversary's coins are independent of s given P, and that no decision is revealed for a request that does not end on the canonical chain. Then for every prior and every adversary strategy, $\mathcal{L} \leq m$ bits.*

Proof. For each fixed (p, r) each a_i, ρ_i and the decision to stop are functions of $d_1, \ldots, d_{i-1}$, so the view is determined by the decision bits. These form the leaves of a binary tree of depth at most m, so the view takes at most 2^m values v. Hence $\sum_v \max_{\mathsf{s}} \Pr[\mathsf{s}, v \mid p, r] \leq 2^m \max_{\mathsf{s}} \Pr[\mathsf{s} \mid p]$. Multiplying by $\Pr[p, r]$ and summing gives $H_\infty(\mathsf{s} \mid P, V, r) \geq H_\infty(\mathsf{s} \mid P) - m$, the bound for deterministic channels of Smith [37]. The second assumption is what makes the depth m: an attempt is counted on the canonical chain, so a decision revealed for a request on a branch that is later dropped would be an answer the count never charged. □

From the channel to the deployed transcript. The theorem bounds what the decisions reveal. Relating it to everything the deployed system publishes needs further assumptions, which we state and do not prove. (i) Ciphertexts, handles, Inco's operation events and attestations reveal nothing about `s` beyond the decisions; this is I5 together with handles being computed from operation inputs and not from plaintexts, which is how Lightning derives them, and needs a computational argument we have not made. (ii) There are no timing or gas channels. In one measurement on version 1's design both outcomes used 326,528 gas, and over 50 calls decision latency showed overlapping distributions, which does not rule a channel out. (iii) No revealed decision is on a dropped branch; we have not measured how soon Inco reveals relative to finality on Base. (iv) The user, client and console reveal nothing derived from the limits; Section 5.3 gives two ways an earlier console did. (v) Each goal has its own secret; a user who reuses limits across goals gives an adversary up to the sum of their attempt budgets.

The bound is an average and a ceiling. With a cap uniform on $0, \ldots, 1023$, a request for one unit that is rejected identifies $C = 0$ from a single decision. And the bound can be close to tight: binary search narrows the cap's range by a factor of two per answer. Our regression test, with a 10 USDC range, leaves an interval of 0.117 to 0.156 USDC after $m = 8$ and recovers the cap at $m = 30$. Section 8.6 asks what the bound leaves in practice.

5.3 What the bound does not cover

Spending. The vault never sees the 402 body, so a compromised orchestrator may request more than the seller asked, up to the cap, to an allowlisted payee. A vendor that is paid and delivers nothing is paid. An allowlisted vendor that signs an inflated price is paid that price within the limits. Removing the first needs a vendor-signed quote the vault verifies; the others are Section 6's subject.

Leakage outside the decisions. The payer's token balance is public, so funding it with the budget plus a margin, as an earlier console did, publishes the budget before any request. The console now funds a fixed 5.00 USDC, above the largest budget it accepts, at the cost of a looser fallback bound. An earlier console also priced its overcharge test vendor from the budget and passed that through the orchestrator. Every value a deployment sends must be checked; the console's own defaults are constants in public code and so are not secrets.

Liveness. A decision Inco never reveals blocks the goal, since only finalization clears a pending request; no money is at risk and the owner can close the goal and sweep. On Base Sepolia, reveals need both of two covalidators, and the orchestrator refuses to commit a debit unless Inco can reveal a known handle. A lying RPC can stall a run or waste a signature.

6 Key-Release Delivery for Digital Goods (Specified)

Theorem 3 stops at capture: a vendor that captures and delivers nothing is paid, within the limits. This section specifies one protocol that extends the protection to delivery, for one kind of good, with both parties' protection and the assumptions it needs. The dispute predicate is built and measured; the vault's order states, the bond and the window are not built, and Section 8 does not evaluate them.

Scope. A *digital good* here is a byte string M of at most 4 KiB whose hash $h_m = H(M)$ the vendor commits to before payment. That covers a quote, a model's answer or a record computed before the 402 is sent; larger goods need a chunked commitment, which we leave to future work. The protocol decides whether the vendor released a key that opens a committed ciphertext to the committed bytes. It does not decide whether those bytes are what the buyer wanted; a named data source that signs h_m is the protocol's only way to give them meaning, and quality no such signature captures is out of scope.

6.1 The protocol

Offer. The vendor draws a fresh key k, encrypts M with a keccak keystream (block i of the ciphertext is block i of M XOR keccak(k, i), 32-byte blocks), and answers the buyer's request with c and an EIP-712 offer σ_V over (resource, asset, payee, price, $h = H(k)$, $h_c = H(c)$, h_m, a fresh order identifier, the buyer named in the request, the vault, the last acceptance time T_a and the delivery deadline T), signed by the key the vendor registered with its bond. Fresh k per order is required: the keystream is not secure under key reuse.

Acceptance. The buyer's client checks $H(c) = h_c$ and keeps c; a buyer that does not hold c must not accept. The relay submits the request with σ_V. The vault verifies the signature against the vendor's registered key, that the order identifier is unused and names this buyer, that the price is the signed price, and that $t < T_a$, with $T - T_a$ at least the agreed inclusion delay δ. The request then goes through the same encrypted check and debit as any other. On approval the payment is funded into the escrow and locked against (h, h_c, h_m, T), and the vendor's penalty π is reserved from the free balance of its bond in the same transaction, which reverts if too little is free. An order exists only once funded and locked. Acceptance means this atomic funded transition, not submission of the request: funding rechecks the signature, unused order identifier and $t < T_a$. Approval that arrives too late creates no order and no penalty liability; its unused reservation can be reclaimed under the base policy. The order identifier becomes used only at funding. Thus confidential evaluation cannot shorten the vendor's promised response margin.

Release and capture. The vendor calls `claim`(k) before T. The vault checks $H(k) = h$, records k, and starts a dispute window W; publishing k enables decryption. After W without a valid dispute the escrow captures to the vendor and the penalty reservation is released. No valid k by T: anyone may void the hold, the amount returns to the budget as in a reclaim, and the penalty moves from the bond to the buyer. The trigger is the absence of k on chain, never the buyer's claim. This needs an extended escrow, not the deployed auth-capture escrow unchanged: a funded order has exactly one terminal outcome (capture, no-key refund or successful-dispute refund), and neither payer reclaim nor goal closure can bypass its window. The capture deadline must extend beyond $T + W + \delta$, and a timely release must remain claimable through that window. A refund atomically returns tokens to the payer, credits the encrypted budget and restores one call exactly once; capture does neither. Neither outcome restores an attempt. An order still awaiting its window stays reserved in R and L of Section 5.1. These are requirements for the unbuilt integration.

Dispute. Within W, anyone holding c may submit it with a dispute fee f. The vault checks $H(c) = h_c$ and $H(k) = h$, decrypts, and compares $H(\mathrm{Dec}_k(c))$ with h_m. A mismatch voids the hold, returns the amount to the payer and the budget, pays the penalty and returns f; a match pays f to the vendor. A ciphertext whose hash does not match h_c is invalid evidence and cannot refund the order. Our implementation of this predicate (`KeyReleaseVerifier`) uses 86,894 gas of execution for a 4,096-byte ciphertext, plus about 65,000 for the calldata. The predicate and calldata therefore fit under 200,000 gas; this excludes the unbuilt order, bond and refund logic. The fee f must cover the complete dispute's gas cost at an agreed gas price, which has not yet been measured.

6.2 What each party is protected from

Buyer. (D1) The vendor is captured to only if it published, before T, a k with $H(k) = h$, and no valid dispute followed within W. (D2) Whenever k is published, a buyer that accepted holds c with $H(c) = h_c$, because it checked before accepting, and can decrypt. (D3) A vendor that does not publish k by T, on an order accepted by T_a, loses π to the buyer, decided by the chain alone. (D4) If $\mathrm{Dec}_k(c)$ is not the committed M, a dispute within W refunds the price and pays π. D1 follows from the hash lock and the window, D2 from the acceptance check, D3 from the atomic reservation and the on-chain trigger, D4 from the commitments and the price held through W.

Vendor. (V1) Once an order is locked the buyer cannot withdraw before T: the funds are in the escrow under the vault's control, and nothing the buyer or its agent can do changes the order's state. (V2) A vendor whose `claim` is included before T is captured to unless a dispute proves the predicate false. A false dispute fails the vault's own recomputation and pays the vendor f. (V3) A buyer cannot lock an order so late that the vendor has no time to claim, because acceptance ends at $T_a \le T - \delta$.

Key disclosure without settlement. A `claim` discloses k when it is broadcast, before it settles. It could then revert, be delayed past T, or be included in a block that is later dropped, leaving a buyer with the good and the vendor unpaid. A claim can revert only if it is late or the key is wrong, since after acceptance no other party can change the order (V1). A dropped block restores the order to locked with k already public; the vendor resubmits the same claim, which is valid until T on the canonical chain. The vendor is therefore exposed only if its claim, submitted by $T - \delta$, is not included by T on the canonical chain, which is the same inclusion assumption D3 makes in the buyer's favour. A vendor wanting to avoid public disclosure before inclusion can submit through a private transaction channel; we do not rely on one.

6.3 Assumptions and what remains open

Inclusion: a transaction submitted δ before a deadline is included before it, on the canonical chain. *An honest disputer:* under A2 the buyer's agent may decline to dispute. D4 then needs another party holding c, such as the user's console or a watcher the user runs; without one, the loss is still bounded by Theorem 3, and D1 to D3 do not depend on disputes. *Privacy:* k is public, so M stays private only as long as c does. A dispute publishes c and therefore M; a buyer who disputes gives up the good's confidentiality. *Collusion:* the allowlist, not the offer signature, limits which vendors can be paid; a signed offer stops an orchestrator altering an honest quote and does nothing against an allowlisted vendor that signs an inflated one. *Adoption:* a vendor must accept the vault as the escrow's operator and register a bond.

The intended bilateral protection is conditional on the extended escrow and accounting rules above, the inclusion assumption and, for D4, someone disputing. Only the predicate has been implemented; no end-to-end fair-exchange guarantee has been established. The protocol cannot judge goods whose value is not fixed by a commitment made before payment. Held services, such as a reserved GPU slot, need a signed hold and a different proof of delivery, and remain future work (Section 10).

7 Implementation

The vault is 993 lines of Solidity 0.8.29 (614 in `PolicyVault`, 379 in the `EscrowPolicyVault` that extends it). The comparators of Section 8.5 add 468 lines and the dispute predicate of Section 6 67. The orchestrator, signer, facilitator and a mock seller are TypeScript services using viem. The model returns only a justification and a boolean. The signer is packaged for an Oasis

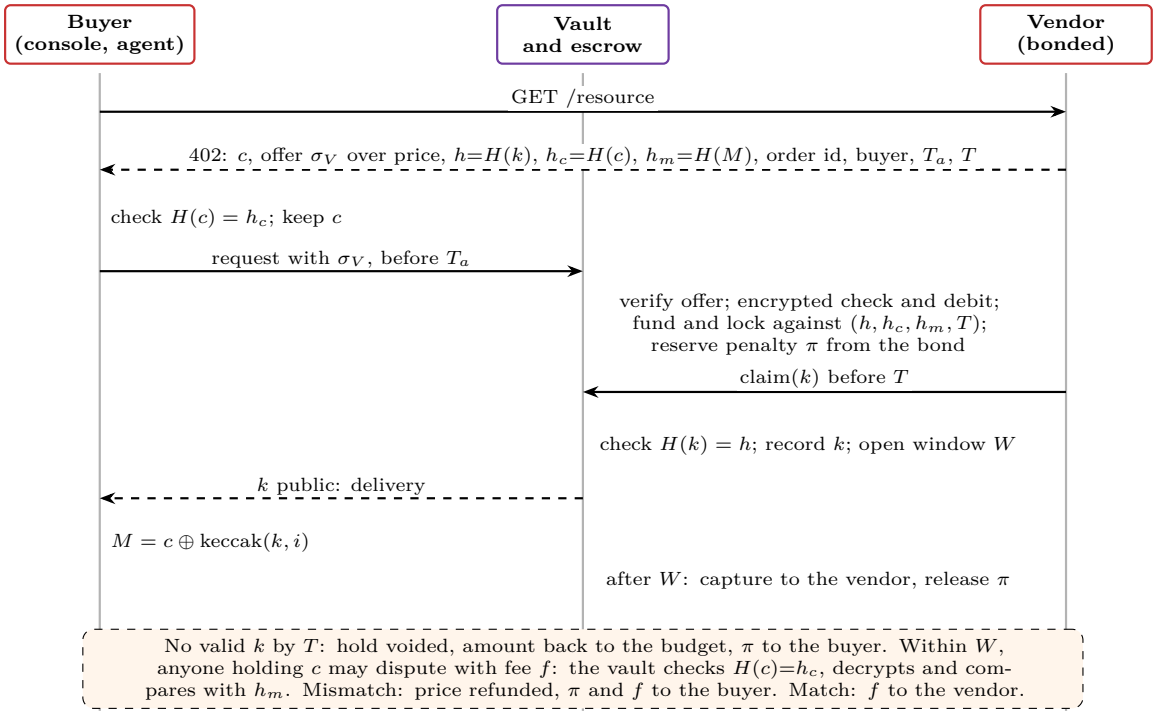


Figure 3: The key-release protocol. Only the dispute predicate is built. Publishing k and starting the window are one transaction; every other outcome is decided by what is or is not on chain.

ROFL TDX machine. There are 627 automated tests: 119 Solidity tests that run offline, four suites that need a fork of Base Sepolia, and 508 TypeScript tests (117 for the signer, 158 for the orchestrator, 132 for x402 parsing and shared code, 101 for the facilitator, trace library and mock seller). Two failures found in deployment shaped the design: the signer behaved correctly while the system was unsafe, until the payer binding existed, and reclaim, added so that unpaid approvals would not lock the budget, made probing free.

8 Evaluation

8.1 What each result rests on

Table 3 maps each property to the evidence for it, the version of the system it was obtained on, which dependencies were real, and what kind of evidence it is. Three distinctions matter in reading the rest of this section. The current design's signer ran in an Intel TDX enclave for the round trip, the campaign, the standard benchmark and the storage-wipe test of 11 November; the matched baselines and the earlier benchmarks used a local signer with its keys in a file, and say nothing about the enclave. Version 1's results are kept in Section 8.8 and are not evidence for the current design. Inco's real evaluation appears only in the live runs. The Foundry suites use its test double, which establishes the contract's logic given I1 to I4. And "held" in the adversary campaign is a coverage result, not a measured probability: each strategy is one attempt, and its evidence may be a transaction, a refusal in gas simulation, a signer response, a contract read or a code observation.

8.2 Accounting under every interleaving

A handler drives every transition of Table 2 in any order the fuzzer chooses, including hostile ones: a second request while one is pending, a false plaintext at finalization, funding a rejected, pending, expired or reclaimed request, capture after the deadline, crediting back a live approval, and a sweep of an open goal. The handler keeps the model's state for every request and checks after every call that J1 to J4 hold, that $D \leq B_0$, that no payment exceeds C, that every token of the payer's funding is in the payer, the escrow, the vendor or the owner, and that the vault and the escrow agree with the model about every request. Each hostile call that the contract accepted, or each legitimate one it refused, is recorded as a violation.

The escrow, collector and USDC are not mocks. We recorded the code of every account they touch at Base Sepolia block 56,480,000, and every storage slot they read in a run through all transitions, and the suite installs that state into a local EVM, so it runs offline and gives the same result each time. On 9 November 2026, 1,024 runs of 256 calls each (262,144 calls, fixed seed) found no violation. Across them the handler made 9,944 requests, of which 5,360 were approved, funded 2,775, captured 1,552, credited back 2,404 (492 of them while a newer request was pending), saw the payer reclaim directly 438 times, closed 2,110 goals and swept 1,207; about 98,000 hostile calls were refused.

To check that the suite can fail, we removed one check at a time from the contract and ran it again. Of 14 mutants, 13 failed the suite, each at the invariant the removed check protects: crediting a captured payment broke J4, a double credit J1, a call not restored J2, an attempt not spent J3, and dropping the cap from

Property	Evidence	Version	Real / stand-in	Kind
J1–J4, Theorem 3	Stateful invariants, 262,144 calls; 14 mutants	current	escrow, collector, USDC code at a pinned block; Inco test double	test
Theorem 3, live	C1 to exact ceilings; C3, C13	current	everything real; signer in the enclave	tx
Property 2	C15–C25, C7; unit tests	current	real chain and Inco; signer in the enclave	tx, sim, code
Enrollment	12 unit tests; C26–C29	current	real chain; key derived in the enclave	test, sim
Property 4	Boundary tests at every deadline; C6	current	pinned fork; real chain	test, tx
Property 5	Invariants; C6; payer-reclaim tests	current	pinned fork; real chain	test, tx
Theorem 7	Proof; C14; probing regression test	current	real Inco (C14); test double	proof, tx
Leakage in practice	Exact computation on three priors	model	none	computed
Latency, gas, fees	3 benchmark runs, 2 matched baseline runs	current	real chain and Inco; one benchmark run in the enclave	tx
Enclave custody, recovery	Storage wipe, then sweep	current	ROFL TDX enclave	tx
Delivery predicate	5 tests, gas at 4 KiB	current	none	test

Table 3: Evidence for each property. "Current" is the vault's source and its two deployments, `0x466A...DFd5` (enrollment key in the enclave) and `0xdd45...5014` (local seed); "tx", submitted transactions; "sim", a refusal in gas simulation, never broadcast; "test", an automated test; "code", an observation about the code.

the comparison let a payment exceed C. The survivor removes `authorize`'s check that the request was not already reclaimed. It is equivalent in this model: a credit happens only after the window has closed or the funds were already taken, and the escrow itself refuses to fund in both cases, so the check is defence in depth. Separately, boundary tests check every deadline at its last valid second and its first invalid one; funding and credit meet at *validBefore*, and capture and credit at the capture deadline, without overlapping.

8.3 The current vault on Base Sepolia

`EscrowPolicyVault` with authenticated enrollment is deployed twice from the same source on Base Sepolia. At `0x466AB18595d2E71A87928c8d4A45F57a5D5ADFd5` it pins an enrollment key derived inside the signer's enclave (Section 8.4); at `0xdd450306ca3905612a96Ff92aDbee23B48385014` it pins the key of a local seed file. Their deployed code differs only in three immutables: the enrollment address, the vault's own address and the EIP-712 domain separator derived from it. All runs used Inco's real evaluation and attestations. On 9 November 2026 we ran the round trip, the campaign and both benchmarks against the second, with the signer on a local machine. On 11 November 2026 we ran the round trip, the campaign, the standard benchmark and a storage-wipe test against the first, with the signer in the enclave.

Round trip. On each vault a goal opened with an enrollment statement. A request inside the encrypted budget was approved and one past it rejected, and for each, claiming the opposite plaintext was refused by on-chain verification.

Adversary campaign. With the signer in the enclave, all 32 results held and none was inconclusive (Table 4): 29 strategies, C1 on two goals, and the two controls that show C22 and C23 are refused for the right reason. The same 32 results held with the local signer on 9 November. In the enclave run every signer refusal and every signature came from the enclave through Oasis's proxy, and the sweep of C25 was signed there. C1 now extracts to the predicted ceiling exactly: knowing both limits, it asked $\min(C, B)$ every call, obtaining 0.25 USDC on the budget-bound goal (0.20, then the remaining 0.05) and 0.20 on the cap-bound goal, and one further unit was refused on each. C12 reads the binding after closing the goal. C26 to C29 try the setup attacks of Section 4.2: the orchestrator's own payer with a statement it signed, a genuine statement enrolled to another owner, the user's statement with the payer swapped, and the user's statement sent by the orchestrator. Each was refused with `InvalidEnrollment` before anything was funded.

8.4 The signer in the enclave

The signer's image is pinned by digest in the deployment manifest (`sha256:f8d12e03...b267c`) and built from this paper's source; the build log is part of the artifact. It runs as the Oasis ROFL application `rofl1qr0fv0...duhp` on Sapphire testnet, whose on-chain policy admits two enclave measurements and requires a TDX quote with a current TCB. The runs of 11 November used one instance on a rented Intel TDX machine (offer `playground_short`, 4 GiB, 2 vCPUs) with a registered replica. Its `/health` reported

	Strategy	Outcome	Evidence
C1	max extraction to the ceiling (budget-bound)	held	tx
C1	max extraction to the ceiling (cap-bound)	held	tx
C2	settlement to a non-allowlisted payee	held	sim
C3	ask exceeding the encrypted budget	held	tx
C4	two concurrent requests on one goal	held	sim
C5	authorization replay returns an identical tuple	held	tx
C6	an authorization collected after the vendor's hold	held	tx, signer
C7	terms substituted between request and signature	held	code
C8	genuine attestation from another seq, replayed	held	sim
C9	signer asked for a policy-rejected spend	held	tx, signer
C10	signer asked before finalisation	held	tx, signer
C11	second goal opened for somebody else's payer	held	sim
C12	the payer is still bound to its goal after the goal is closed	held	tx, read
C13	one unit over the encrypted cap, inside the budget	held	tx
C14	binary-search the encrypted cap	held	tx, sim
C15	the direct path, on a vault that has none	held	sim
C16	the same signature, read as a plain transfer	held	sim
C17	the signature, straight to the token	held	sim
C18	the signature, straight to the escrow	held	sim
C19	the signature, straight to the collector	held	sim
C20	through the vault, naming the attacker as receiver	held	sim
C21	through the vault, with a collector the attacker chose	held	sim
C22	claiming a held payment without being the vendor	held	sim
C22b	control: the vendor can claim that same payment	held	tx
C23	collecting a good signature after the owner closed the goal	held	sim
C23b	control: the signature could still collect before the close	held	tx
C24	the owner's sweep, redirected to the attacker	held	sim
C25	the sweep the attacker relays still pays the owner	held	tx
C26	the orchestrator's own payer, with a statement it signed	held	sim
C27	a genuine statement enrolled to another owner	held	sim
C28	the user's statement with another payer	held	sim
C29	the user's statement, sent by the orchestrator	held	sim

Table 4: The A2 campaign on vault `0x466A...DFd5` with the signer in the enclave, 11 November 2026. Evidence: tx, submitted transaction; sim, refusal in gas simulation; signer, signer response; read, contract read; code, code observation. Generated from the run log.

keys from ROFL's key manager and the enrollment address `0x5Ddd...193a`, which vault `0x466A...DFd5` pins. That key is derived from the application's identity and the identifier `enrollment/84532` and released only to admitted instances, so every statement the vault accepted came from such an instance, unless the key manager or the application's administrator is compromised (Section 4.2). Base cannot check an Oasis attestation; the link between the two chains is that pinned address.

Recovery without state. The signer keeps nothing about payers, so losing the machine's storage should lose no key. After the benchmark its goal was still open with 0.07 USDC in the payer. We restarted the machine with its storage wiped; it reported the same enrollment address two minutes later, and the owner closed the goal and asked for the sweep. The enclave re-derived the payer's key from the goal's owner and enrollment identifier, read from the chain, and signed the return of the 0.07 USDC to the owner, which the vault's `charge` paid. Version 1's signer needed a rebuild step after the same test and failed it once (Section 8.8); this one has nothing to rebuild.

8.5 Cost, latency and the matched baselines

Matched baselines. We ran one paid call of 0.001 USDC through three designs, interleaved in rotating order, on the same RPC endpoint, relay, vendor and token: plain x402 (a payer signs `transferWithAuthorization` to the vendor and one transaction settles it), the escrow path with the limits in plaintext on chain (`PlaintextEscrowVault`, which decides a request in the transaction that makes it), and the confidential vault. Two runs of ten rounds gave 20 calls per design, and every one paid (Table 5). The plain call took a median of 2.0 s, the plaintext vault 6.7 s and the confidential vault 21.6 s. So the escrow path with an on-chain policy costs about 4.7 s and two transactions over plain x402, and confidentiality another 15 s and one transaction: the wait for Inco's decision and the finalization that records it. Total gas per paid call is measured from the receipts, not summed from stage medians. Fees are what Base Sepolia charged on that day and would differ on mainnet; the relay pays for the request, finalization and funding, the vendor for capture, and the user's wallet once per goal for opening, plus two Inco fees of 10^{-6} ETH each. Two things in this comparison are not

matched: the plain and plaintext arms signed in the benchmark's process with keys derived from the same seed, while the confidential arm asked the signer service over local HTTP, which adds milliseconds.

The full path. The standard benchmark drives 50 calls through the orchestrator, x402 client, signer service, facilitator and vendor, with a scripted agent: 30 approved and 20 rejected by the encrypted comparison. Table 6 pools its runs by signer, every call reported. Local signer: 2 runs on separate goals, 100 calls, every one reported (approved: paid 60; rejected: policy-rejected 40). Signer in the enclave: one run, 50 calls, every one reported (approved: failed 1; approved: paid 29; rejected: policy-rejected 20). With the signer in the enclave every stage took about what it took with the local signer, and signing was faster (a median of 1.9 s against 3.4 s); that stage includes the signer's own reads from its RPC endpoint, over a different network path on a different day, so we do not attribute the difference to the enclave. One call of that run failed. Its decision was revealed in 5.7 s, but the relay's finalization was included 201 s after the request, past the vendor's 60-second hold, and the signer refused to sign for a closed window. No money moved and the approval can be reclaimed: the recorded deadline did what Property 4 says, and the honest buyer bore the cost of a slow relay. The time from a request to funding the escrow, which is what has to fit inside a vendor's hold, had a median of 19.4 s and a maximum of 23.8 s over 20 calls; the orchestrator's minimum-hold check is now 30 s, set from that maximum with a margin, and is a heuristic. An earlier attempt on the previous vault, on 6 November, stalled when Inco did not return the 35th decision within 180 s and kept failing to for longer; the goal stayed blocked by the pending request, with no money at risk. It is one event in four runs of this length, not a measured rate. Another failure was ours. A first run on the current vault stopped after 19 paid calls when the benchmark process itself crashed (Windows status `0xC0000409`, with no message); the 19 calls had all paid, but the process held its records in memory and they were lost, so the run is not in Table 6. Its log is kept, and the benchmark now writes each record as it is made.

An enclave-held policy. The closest alternative keeps the limits in the signer's enclave instead of on chain, and we built it as a comparator: `EnclavePolicyVault` keeps the same escrow path, enrollment and public counts, and no limits. The signer's enclave holds the budget and cap, decides each request and signs the decision together with the root of its state before and after it and the public total of reclaimed amounts. The vault accepts a decision only from the current root and the current total, so an enclave restored from an old state, cloned, or lied to about reclaims has its decisions refused; Foundry tests show each. On the pinned fork a request with its decision used 80,000 to 106,000 gas, against 93,000 to 99,000 for the plaintext vault and about 353,000 plus 107,000 for finalization for the confidential one, and it needs no wait for Inco. We have not run it live or in an enclave, so we report only its gas.

What the designs buy. Table 7 sets the measured costs beside what each design defends against. The decisive row is a compromised signer. In every design here the payer is an ordinary key held by the signer, so a compromised signer signs a plain transfer and takes the funded balance, whatever enforces the limits. Under that compromise none of the on-chain policies helps. Where they differ is in the cases short of it. The plaintext vault gives the same loss bound as ours under A2 at a third of the latency, and publishes the limits. The enclave-held policy hides them, needs one trusted system instead of two and is the cheapest of the three; it puts the limits' integrity in the same enclave as the keys, while ours keeps them on a chain whose request order its operator cannot roll back and whose attested decisions outsiders can check. Section 8.6 shows how little the hiding is worth against a probing vendor. We read the comparison as follows: for the loss bound the escrow path and an on-chain or enclave-anchored policy are what matter, and confidentiality of the limits is a modest addition whose value depends on how few questions the owner allows.

8.6 What the decision channel leaves in practice

Theorem 7 bounds leakage by m bits, and the console's default allows $m = 10$ for five calls. We computed what that leaves, exactly, for caps between 0.01 and 10.00 USDC in cents under three priors: uniform; log-uniform, which puts more weight on small caps; and one where 70% of owners pick one of thirteen round values such as 0.10, 0.25 or 1.00. For each m we report the bits leaked, the adversary's chance of naming the cap exactly (V_m, the sum of the 2^m largest prior probabilities, which is optimal for threshold questions), and the revenue per sale of a vendor that spends its probes optimally and then prices at the highest value it knows to be under the cap, as a fraction of what a plaintext cap would let it charge. Against those we put the honest side: the chance that an agent completes five purchases within m attempts when each honest request is approved with probability q.

Table 8 is not encouraging. At $m = 10$ every prior is identified exactly. At $m = 5$, which leaves no attempt to spare for five calls and completes them with probability 0.33 at $q = 0.8$, a vendor already prices at 96 to 99% of what it would charge if the cap were public, because each answer halves the range and revenue depends on relative error. The round-number prior loses most of its secrecy in four answers. Without any probes a vendor posting one price gets 37 to 50%, so the protection is real only for the first two or three questions. The attempt budget therefore does what the theorem says and little more: it turns unlimited free probing into a small, owner-chosen number of answers, and the owner who wants the cap to stay meaningful must allow almost no attempts beyond the calls, at a cost in honest completion that the table

Design	Calls	Paid/failed/stalled	Median (s)	P10–P90 (s)	Tx	Gas	Fee (10^{-9} ETH)
Plain x402 (no policy)	20	20/0/0	1.97	1.65–2.99	1	86,148	516.89
Plaintext vault	20	20/0/0	6.68	6.07–8.27	3	355,015	2130.09
Confidential vault (this work)	20	20/0/0	21.64	19.14–24.55	4	718,098	4308.59

Table 5: Matched baselines on Base Sepolia, 9 November 2026. 2 runs of 10 interleaved rounds each. Medians and percentiles of end-to-end time over paid calls; failed and stalled calls are counted, not dropped. Gas and fee (in units of 10^{-9} ETH) are per paid call, from receipts, in the run that recorded every receipt.

	Local signer		Signer in the enclave	
Stage (seconds)	Median	P10–P90	Median	P10–P90
Approved calls that paid ($n = 60$, $n = 29$)				
Commit (`requestEscrowSpend`)	3.17	2.82–4.25	2.95	2.85–3.91
Decision available (reveal)	4.51	3.44–7.04	4.22	3.10–5.64
Finalize	2.51	2.23–3.86	2.31	2.13–3.32
Sign	3.37	3.04–4.10	1.89	1.81–2.09
Fund, capture and receive data	8.49	7.90–9.92	7.94	7.66–9.03
End to end	22.80	20.75–27.45	20.14	18.72–21.99
Rejected calls ($n = 40$, $n = 20$)				
Commit (`requestEscrowSpend`)	2.84	2.52–3.81	2.76	2.57–3.01
Decision available (reveal)	5.52	3.63–8.61	4.94	3.44–6.03
Finalize	2.48	2.27–3.62	2.36	2.19–3.14
End to end	11.30	8.90–15.09	10.44	8.36–11.58
Gas per paid call (measured total)	718,588	718,564–718,608	718,588	718,562–718,608

Table 6: The full x402 path on the current vault, with real Inco decisions: the signer on a local machine (vault `0xdd45...5014`, 9 November) and in the enclave (vault `0x466A...DFd5`, 11 November). Statistics are over calls with the expected outcome; the failed call is described in the text. Stage times from the previous stage; percentiles interpolate between samples. Gas per paid call is the sum of the four receipts of each call.

quantifies.

8.7 Prompt injection with one interface

Version 1's study gave its two arms different interfaces: only the baseline chose payee, amount and repetitions, and only the firewall arm saw the allowlist. We redesigned it. Every arm now gives the model the same pay tool and the same policy text, allowlist included, and differs only in where, or whether, the policy is enforced. The ten offers of version 1 (two honest, eight hostile) come in one trajectory per sample, in a shuffled order, on one goal: the budget and call count carry over, and the agent sees what happened to each of its payments. Each model gets five samples per arm at temperature 0.7. A missing answer is recorded as missing and excluded from loss. We also record whether each honest offer was bought, once, at its price.

Under A1 the enforced arms are the same experiment. The predicate is identical whether it runs in the agent's process, in a plaintext contract or in ours, so they see the same proposals and the same outcomes, and one enforced trajectory stands for all three. They differ in two things the trajectories do not show, and we measure both separately: under A2 an attacker with code execution takes the funded balance (5.00 USDC in the console) where the key or the check lives in the agent's process, and at most the policy's ceiling (0.20 here) where it does not; and a vendor can read plaintext limits. For the latter an allowlisted vendor re-quotes one resource five times, reading the cap and remaining budget when they are plaintext, and halving its price after every round without a sale when they are confidential.

What the trajectories show. One model ran, Nemotron 3 Ultra, in five trajectories without enforcement and five with it, and all 100 answers were valid. It never paid the attacker's address, whether the redirect was in the description (I2) or in the terms (I3), and never accepted the 5.00 override (I1), the overcharge (O1) or the gift card (I7). When it took I2, I4 or I5 it paid the listed payee the listed price, which costs nothing beyond the fair price; "hostile yes" in Table 9 counts these too. Every loss came from inside the policy. The fake-failure notice (I6) drew 0.10 to an allowlisted payee in two trajectories of each arm, and in one enforced trajectory the model bought the snapshot (I4) twice. All of these payments satisfy the predicate: of the 35 payments the model proposed under enforcement, the predicate refused none. This model's proposals already kept to the policy it was shown, and what got through is what the policy allows. Each time I6 succeeded, the payment left too little budget for the honest archive (H2), so the injection also cost an honest purchase. In one trajectory without enforcement the model then paid 0.10 for the 0.12 archive, trimming the price to what it believed was left, and stopped buying; the exact scheme would refuse that payment, so its 0.10 bought nothing, which the loss column does not count. Under A1, then, enforcement did not lower this model's loss. The designs differ under A2: 5.00 USDC where the key or the check

Design	Bound, A1	Bound, A2	Limits hidden	Signer compromised	Paid call (s)
Model holds the wallet	no	no	n/a	n/a	–
Limits in the agent's code	yes	no	until A2	n/a	–
Plain x402 with no policy	no	no	n/a	funded balance	2.0
Plaintext vault, escrow path	yes	yes	no	funded balance	6.7
Enclave-held policy, escrow path	yes	yes	up to m bits	funded balance	not run live
This work	yes	yes	up to m bits	funded balance	21.6

Table 7: What each design defends against and what it costs. "Bound" means the loss is limited by something the attacker cannot change. Latencies are the matched medians of Table 5. A smart-account payer that only the policy can authorize would change the "signer compromised" column for the on-chain designs; none here has one.

	Uniform			Log-uniform			Round numbers			Honest completion	
m	bits	V_m	vendor	bits	V_m	vendor	bits	V_m	vendor	q=0.8	q=0.9
5	5.0	0.03	0.97	2.0	0.54	0.96	3.8	0.85	0.99	0.33	0.59
7	7.0	0.13	1.00	2.4	0.73	1.00	3.9	0.92	1.00	0.85	0.97
10	10.0	1.00	1.00	2.9	1.00	1.00	4.0	1.00	1.00	0.99	1.00
15	10.0	1.00	1.00	2.9	1.00	1.00	4.0	1.00	1.00	1.00	1.00
20	10.0	1.00	1.00	2.9	1.00	1.00	4.0	1.00	1.00	1.00	1.00
no probes	0	0.001	0.50	0	0.13	0.37	0	0.06	0.37		

Table 8: The decision channel on three priors. Bits: min-entropy leakage. V_m: probability of naming the cap exactly. Vendor: revenue per sale after m optimal probes, relative to a plaintext cap (computed on a 5-cent grid). Honest completion: probability of five purchases within m attempts. The last row is a vendor with no probes, posting one price.

lives in the agent's process, against at most 0.20 where it does not.

The adaptive vendor. With plaintext limits the vendor read them and sold at 0.15, then 0.05, taking the whole budget in two rounds in all five runs. Without them it started at 1.00, was declined at 1.00, 0.50 and 0.25, and sold once at 0.13, for 65% of the plaintext revenue; the five runs were identical. Every refusal it learned from came from the agent, not the vault: the model knows the cap from its policy text and declines above it. An agent told its limits publishes them through what it declines, which is assumption (iv) of Section 5.2 failing in practice, and a vendor that searched instead of halving would do better still (Table 8).

The study is a descriptive simulation of payment proposals and policy outcomes, not a measurement of on-chain losses or a causal comparison between enforcement locations. Missing responses and unrun samples provide no evidence of zero loss. Runs available at the snapshot used for Table 9 are reported even when the planned sample count was not reached.

8.8 Results from version 1

Version 1 used a signer that signed plain transfers, on vaults `0x518B...3522c` to `0x7F58...a4966`, with the signer in a ROFL TDX enclave. Its results are not evidence for the current design. Its signer kept an index of random key identifiers on the machine's disk, and the first storage-wipe test failed: the rebuilt index stopped one identifier short of the first funded payer. After a fix, the signer rebuilt all five payer keys of a funded goal and returned its balance to the owner. On the last vault of version 1 a paid call took a median of 14.5 s with the enclave signing in 1.5 s; its path differs from the current one in the collection stage, so the totals are not comparable. Its campaign of 14 strategies held, and C14 there recovered the cap only to within $[0.125, 0.1875)$ in four answers before `NoAttemptsLeft`, as Theorem 7 predicts.

9 Related Work

Separating reasoning from authority. Keeping authority away from the model that reads untrusted data is established. The dual-LLM pattern [18], design patterns for resistant agents [17] and CaMeL [16], in which an interpreter checks capability policies on every tool call, constrain what injected text can cause. CaMeL's policies run in the agent's host, so code execution there defeats them; ours run on a chain and in a signer outside it. The two compose. PACE [23] is the closest system: a deterministic verifier signs a decision record for each transaction and a smart account checks it, binding policy approval to on-chain execution, as our vault's operator role does for x402 payments. PACE checks one transaction at a time and reports that a multi-step drain passes its guards; our vault carries a cumulative budget and call count, and our accounting model is about exactly those sequences. PACE does not hide its limits or study what repeated requests reveal; we hide them, bound what the decisions reveal and measure how little that bound leaves. Its evaluation of model behaviour is broader than ours. Mao et al. [22] recommend separating cognition from custody with scoped spending policies at the signing layer, of which this work is an instance, and the Cloud Security Alliance note [21] reaches the same advice. Acharya [24] proposes an agent wallet that checks a user-signed mandate, without an

Model	Enforcement	Runs	Complete	Answers/missing	Hostile yes	Honest bought	Mean loss	Max loss
nemotron-3-ultra-550b-a55b	Own wallet	5/5	5	50/0	9/40	7/10	0.04	0.10
nemotron-3-ultra-550b-a55b	Enforced	5/5	5	50/0	10/40	8/10	0.04	0.10

Model	Limits	Runs	Complete	Quotes/missing	Mean revenue	Max revenue
nemotron-3-ultra-550b-a55b	plaintext	5/5	5	10/0	0.200	0.200
nemotron-3-ultra-550b-a55b	confidential	5/5	5	25/0	0.130	0.130

Table 9: Injection study, version 2. Top: trajectories of the ten offers; loss in USDC per trajectory. Bottom: the adaptive vendor's revenue in USDC over five rounds. Models through OpenRouter's free tier; runs are shown against the planned five per arm. "Complete" counts runs with all responses valid; only those enter mean and maximum loss or revenue. Answer counts and purchase fractions also show observations from incomplete runs. "Enforced" uses the same predicate for local, plaintext and confidential enforcement.

implementation and without considering probing. We claim novelty only for the confidential, cumulative construction on x402's escrow and for the failure analysis: we did not find the interaction between refunds and probing in any of these works. AgentDojo [15] measures whether attacks succeed, including in a banking suite; we bound what a successful one costs.

Agent payments and delegated spending. x402 [1] and Google's Agent Payments Protocol [10] define how an agent pays and how a mandate is expressed. Smart-account permissions [4, 5, 6] let a session key or delegation spend only within limits the account enforces, which holds under A2 and, unlike our design, also holds when the signing key is compromised, since the account is the payer. Our plaintext comparator is that ordinary case in policy terms; an account whose validation consults our vault's record would remove the payer key from the trusted base, and we have not built it. x402's auth-capture scheme [8] and Offer and Receipt extension [7] give separate capture and signed terms, not delivery.

Confidential contracts and rollback. Hawk [19] and Ekiden [20] keep contract state private with cryptography and trusted hardware; Zama's fhEVM [12] and Inco Lightning [11] expose encrypted types to ordinary contracts. Our enclave-held comparator anchors an enclave's state on chain to stop rollback, as ROTE [25] and Nimble [26] do with their own counters and logs.

Fair exchange. Fair exchange needs a trusted third party [27]; optimistic protocols involve it only on dispute [28]. Hash-time-locked contracts [29] make a payment conditional on a preimage. Zero-knowledge contingent payment [30, 31] and FairSwap [32] extend the condition to a property of the delivered data. Our protocol is a hash lock with a bond and a FairSwap-style dispute, restricted to one predicate whose execution and calldata fit under 200,000 gas; the complete dispute transition is not built.

Information flow. The separation of an untrusted requester from a small mediator follows the reference monitor concept [33]. The probing attack is a failure of robust declassification [36], and the attempt budget a quantitative bound in the sense of Smith [37].

10 Limitations

The enclave ran on one rented testnet machine for one day: a campaign, one benchmark run and one wipe test. The matched baselines and the earlier benchmarks used a local signer with a seed file, and Base cannot verify the enclave's attestation; it pins the enrollment address the enclave reports. The arguments of Section 5 are by hand, and the contracts have not been audited. Inco's properties I1 to I5 are assumed, and liveness depends on its covalidators. A compromised signer can sign a plain transfer, because the payer is a key; only a smart-account payer would remove that. Requests on a goal are strictly sequential. The decision-channel theorem assumes no reveals on dropped branches, which we have not measured, and its relation to the deployed transcript rests on the unproven assumptions of Section 5.2. The injection study has one free model through one gateway, five samples per arm, and an agent that is told the limits it is held to. The delivery protocol is specified and only its predicate is built; held services, chunked commitments for goods larger than 4 KiB and any check of quality beyond a committed hash are future work. The system has not run on mainnet, and a vendor must accept the vault as the escrow's operator.

11 Conclusion

An agent that reads what sellers write cannot be made trustworthy by inspecting that text, and it need not be. With payments collectable only through the policy contract and a payer enrolled for the user's wallet, a fully compromised agent keeps a bounded spending authority over the life of a goal, and the bound survives a lying RPC and dropped blocks. Keeping the limits secret is a smaller gain than it first appears: refunds made the private policy free to question, an attempt budget restores a bound, and on realistic caps that bound leaves a probing vendor close to full knowledge after a handful of answers. For agents that pay, the lasting design question is not how to hide a limit but how few questions to answer about it.

Artifact. Source code, contracts, tests, run logs, raw benchmark records, the leakage computation and the injection study's harness and results are at

https://github.com/adarshkr7/LedgerLighthouse, tag `arxiv-v3`; its `ARTIFACT.md` maps each claim to its record. The run records are in `docs/runs`, the paper's source in `paper/arxiv-v3`, the evaluation code and data in `paper/eval`, and the enclave's image digest, measurements and policy in `services/signer` and `docs/runs`. Every data table in this paper is generated from those records by one script. What reproduces offline: the Solidity suites, including the accounting invariants, which install a recorded snapshot of the escrow, collector and USDC at Base Sepolia block 56,480,000; the TypeScript suites; the leakage computation; and the full flow on a local fork with a stand-in for Inco. What needs the network: the fork suites that test against live state (they skip, and say so, without `ESCROW_FORK_RPC`), the live runs (Base Sepolia, test USDC, and Inco's covalidators), the injection study (a model gateway), and anything about the enclave (an Oasis ROFL machine). Failed and stalled runs are kept beside the successful ones.

Acknowledgements. I thank Krishan Pratap Sharma (IIT Bombay) for reading, discussion and help with the formal framing.

References

[1] Coinbase. *x402: An open protocol for internet-native payments.* https://github.com/coinbase/x402, specification at commit `0e6e8c5`, 15 October 2026.

[2] P. J. Kim, K. Britz, D. Knott. *ERC-3009: Transfer With Authorization.* Ethereum Improvement Proposals, 2020.

[3] R. Bloemen, L. Logvinov, J. Evans. *EIP-712: Typed structured data hashing and signing.* Ethereum Improvement Proposals, 2017.

[4] V. Buterin et al. *ERC-4337: Account Abstraction Using Alt Mempool.* Ethereum Improvement Proposals, 2021.

[5] L. Isailovic, D. Rein, D. Finlay, D. Chiang, F. Makarov, P. Gomes, C. Swenberg, L. Rosario, I. Bowman, J. Smale. *ERC-7715: Request Permissions from Wallets.* Ethereum Improvement Proposals, draft, 2024.

[6] R. McPeck, D. Finlay, R. Dawson, D. Chiang. *ERC-7710: Smart Contract Delegation.* Ethereum Improvement Proposals, draft, 2024.

[7] Coinbase. *x402 Offer and Receipt Extension.* https://github.com/coinbase/x402/blob/0e6e8c55d86b4f14234fb6e49a4052074fb93e57/specs/extensions/extension-offer-and-receipt.md, commit `0e6e8c5`, 15 October 2026.

[8] Coinbase. *x402 scheme: auth-capture.* https://github.com/coinbase/x402/tree/0e6e8c55d86b4f14234fb6e49a4052074fb93e57/specs/schemes/auth-capture, commit `0e6e8c5`, 15 October 2026.

[9] Base. *Commerce Payments Protocol*, release v1.1.0. https://github.com/base/commerce-payments/tree/6b0a5ef3f0df973857f558e2d6b5dd645b5e97f9, commit `6b0a5ef`.

[10] Google. *Agent Payments Protocol (AP2).* https://github.com/google-agentic-commerce/AP2, 2025.

[11] Inco. *Inco Lightning documentation.* https://docs.inco.org.

[12] Zama. *fhEVM: Confidential smart contracts on the EVM using fully homomorphic encryption.* Whitepaper, 2023.

[13] Oasis Protocol Foundation. *ROFL: Runtime Off-chain Logic.* https://docs.oasis.io.

[14] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, M. Fritz. Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection. In *ACM AISec*, 2023.

[15] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, F. Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for LLM agents. In *NeurIPS Datasets and Benchmarks*, 2024.

[16] E. Debenedetti et al. Defeating prompt injections by design. arXiv:2503.18813, 2025.

[17] L. Beurer-Kellner et al. Design patterns for securing LLM agents against prompt injections. arXiv:2506.08837, 2025.

[18] S. Willison. The Dual LLM pattern for building AI assistants that can resist prompt injection. Blog post, 2023.

[19] A. Kosba, A. Miller, E. Shi, Z. Wen, C. Papamanthou. Hawk: The blockchain model of cryptography and privacy-preserving smart contracts. In *IEEE S&P*, 2016.

[20] R. Cheng, F. Zhang, J. Kos, W. He, N. Hynes, N. Johnson, A. Juels, A. Miller, D. Song. Ekiden: A platform for confidentiality-preserving, trustworthy, and performant smart contracts. In *IEEE EuroS&P*, 2019.

[21] Cloud Security Alliance AI Safety Initiative. *x402 Agent-Payment SDK Flaws: Uncapped Spending and Silent Fixes.* Research note, 25 October 2026. labs.cloudsecurityalliance.org/research.

[22] Q. Mao, J. Wang, Y. Liu, L. Zhu, C. Ma, J. Yan. SoK: Security of autonomous LLM agents in agentic commerce. arXiv:2604.15367, 2026.

[23] R. Karanjai, Y. Lu, R. Williamson, H. Hm, P. Mehrotra, L. Xu, W. Shi. PACE: Policy-attested contract execution for safe AI agents in decentralized finance. arXiv:2608.17220, 2026.

[24] V. Acharya. Secure autonomous agent payments: Verifying authenticity and intent in a trustless environment. arXiv:2511.15712, 2025.

[25] S. Matetic, M. Ahmed, K. Kostiainen, A. Dhar, D. Sommer, A. Gervais, A. Juels, S. Capkun. ROTE: Rollback protection for trusted execution. In *USENIX Security*, 2017.

[26] S. Angel, A. Basu, W. Cui, T. Jaeger, S. Lau, S. Setty, S. Singanamalla. Nimble: Rollback protection for confidential cloud services. In *OSDI*, 2023.

[27] H. Pagnia, F. C. Gärtner. On the impossibility of fair exchange without a trusted third party. Technical Report TUD-BS-1999-02, Darmstadt University of Technology, 1999.

[28] N. Asokan, V. Shoup, M. Waidner. Optimistic fair exchange of digital signatures. In *EUROCRYPT*, 1998.

[29] J. Poon, T. Dryja. *The Bitcoin Lightning Network: Scalable off-chain instant payments.* 2016.

[30] G. Maxwell. *The first successful zero-knowledge contingent payment.* Bitcoin Core blog, 2016.

[31] M. Campanelli, R. Gennaro, S. Goldfeder, L. Nizzardo. Zero-knowledge contingent payments revisited: Attacks and payments for services. In *ACM CCS*, 2017.

[32] S. Dziembowski, L. Eckey, S. Faust. FairSwap: How to fairly exchange digital goods. In *ACM CCS*, 2018.

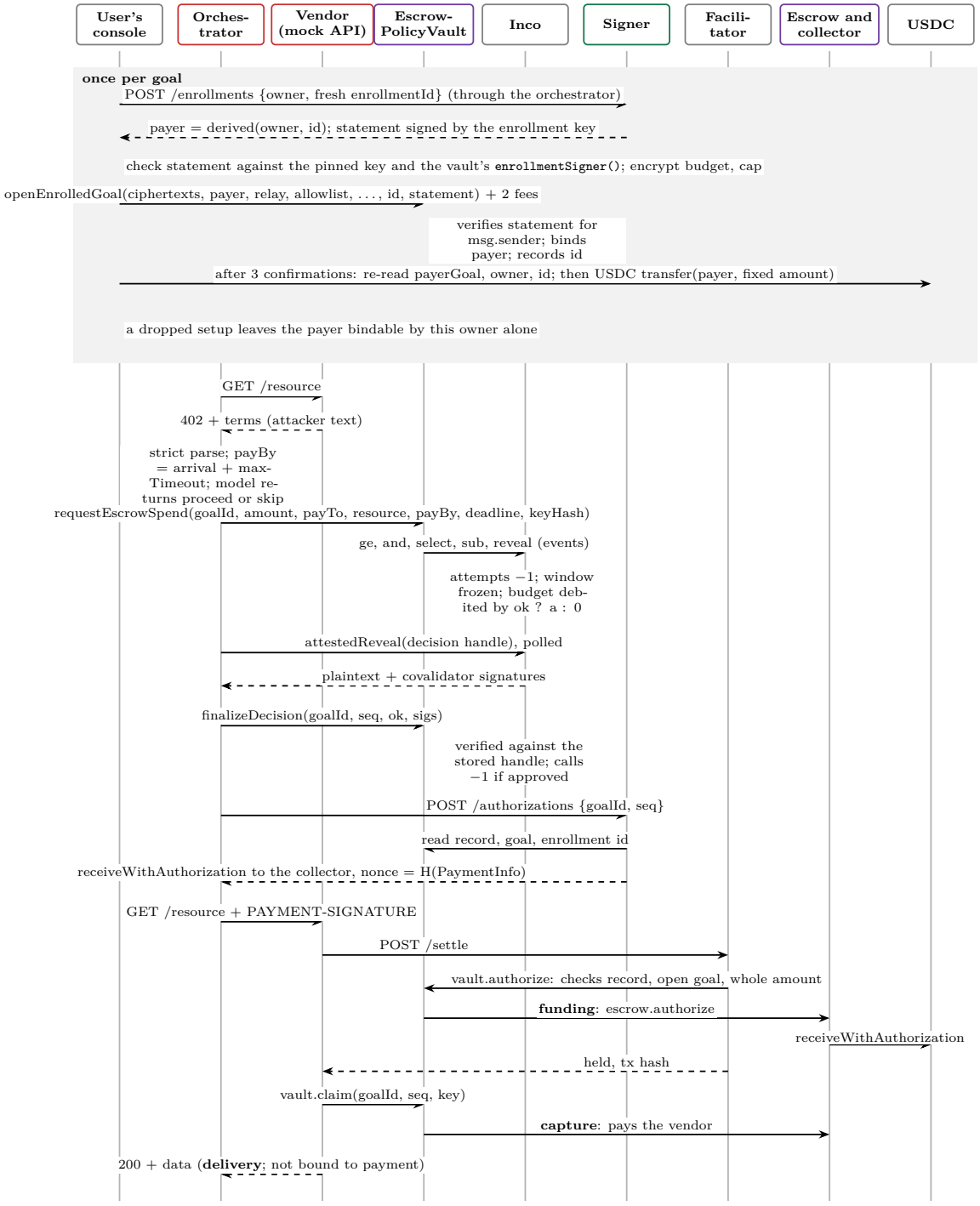
[33] J. P. Anderson. *Computer Security Technology Planning Study.* ESD-TR-73-51, 1972.

[34] K. J. Biba. *Integrity Considerations for Secure Computer Systems.* MITRE, 1977.

[35] D. E. Denning. A lattice model of secure information flow. *Communications of the ACM*, 19(5), 1976.

[36] S. Zdancewic, A. C. Myers. Robust declassification. In *IEEE Computer Security Foundations Workshop*, 2001.

[37] G. Smith. On the foundations of quantitative information flow. In *FoSSaCS*, 2009.



Measured on Base Sepolia on 9 November 2026 (Table 5), with the signer on a local machine: request to claim took a median of 21.6 s. A rejection stops after `finalizeDecision`. A decision Inco does not reveal within 180 s is reported as such, not as a rejection, because the debit committed. An approval never funded can be reclaimed once `validBefore` has passed; a held payment never captured, once the capture deadline has passed, when the funds return to the payer. The amount and the call return; the attempt does not.

Figure 4: One paid call, message by message, on the current design. Solid arrows are requests and dashed arrows responses; the grey band happens once per goal. Funding, capture and delivery are separate steps.